

SENTINEL

Personal Digital Security AI

Product Requirements Document (PRD) + Technical Requirements Document (TRD)

Document	Value
Version	1.0
Status	Initial architecture and MVP specification
Date	2 August 2026
Product class	Personal cybersecurity / defensive AI
Primary principle	Local-first, least privilege, explainable, human-authorized response

Product thesis: SENTINEL is a personal security operations center that correlates account, device, network, privacy and threat-intelligence signals, converts them into explainable risk, and guides or executes narrowly authorized defensive actions.

Part I - Product Requirements Document

1. Executive Summary

SENTINEL is an AI-assisted personal digital security platform for individuals who need a unified view of their digital risk. Instead of behaving like a generic cybersecurity chatbot, it maintains an asset inventory and Personal Security Graph, ingests security signals, correlates related events, prioritizes risk, explains evidence, and drives structured remediation workflows.

The product is defensive by design. SENTINEL must not silently perform destructive or high-impact actions. The default execution model is Observe -> Analyze -> Recommend -> Request Approval -> Execute -> Verify -> Audit.

2. Problem Statement

- Personal security is fragmented across email providers, password managers, device settings, browsers, operating systems and breach-notification services.
- Most users receive isolated alerts without understanding whether multiple weak signals form one serious incident.
- Security tools often expose technical data without translating it into prioritized, actionable decisions.
- AI assistants can become a new security risk if they receive broad system permissions or are allowed to execute unverified instructions.

3. Goals and Success Criteria

Goal	Success measure
Unified posture	User can see accounts, devices, networks and active risks from one dashboard.
Explainable detection	Every material alert includes evidence, confidence, affected assets and recommended next steps.
Fast triage	Common phishing/URL/account-risk checks return a useful assessment within seconds, excluding third-party latency.
Controlled response	High-impact actions cannot execute without an explicit policy grant or user approval.
Auditability	Security-relevant agent decisions and actions are recorded in an append-oriented audit trail.
Privacy	Sensitive raw telemetry is minimized and kept local where feasible; cloud AI receives only policy-approved context.

4. Non-Goals

- Replacing enterprise EDR, SIEM or SOC platforms in the initial product.
- Autonomous penetration testing, exploitation, credential attacks or offensive scanning.
- Guaranteed malware detection or a claim that a numerical score proves a user is 'safe'.
- Storing plaintext passwords, recovery codes or unrestricted authentication tokens.
- Giving an LLM direct, unrestricted shell or administrator access.

5. Target Users

Persona	Need
Everyday user	Clear protection guidance without cybersecurity expertise.
Developer / power user	Device, repository, account and network visibility with evidence.
Freelancer / founder	Protect high-value accounts, client data and multiple devices without operating a full SOC.
Family administrator (later)	Manage delegated security posture while respecting account boundaries and consent.

6. Product Principles

- Evidence before assertion: distinguish observed facts, external intelligence, inference and uncertainty.
- Least privilege: each connector and agent receives only the permissions required for its job.
- Local-first processing for sensitive telemetry when practical.
- Human control over high-impact remediation.
- Deterministic policy enforcement outside the LLM.
- Fail closed for authorization and fail safely for unavailable integrations.
- No single opaque 'AI score': show score components and evidence.

7. Core User Experience

1. Onboard: create the local SENTINEL vault, choose privacy mode, and connect supported accounts/devices.
2. Discover: build an inventory of protected assets and their relationships.
3. Assess: calculate risk from posture, exposure, suspicious activity and threat intelligence.
4. Alert: surface prioritized findings with severity, confidence and evidence.
5. Respond: provide a remediation plan; request approval for controlled actions.
6. Verify: confirm whether remediation succeeded and recalculate risk.
7. Review: preserve a security timeline and audit history.

8. Functional Requirements

ID	Requirement	Priority
FR-01	Asset inventory for accounts, devices, networks, applications and identifiers.	P0
FR-02	Personal Security Graph linking assets, exposures, alerts and incidents.	P0
FR-03	Security dashboard with posture score, critical findings and recommended actions.	P0
FR-04	Phishing analysis for pasted text, email content, URLs and supported QR/image inputs.	P0
FR-05	URL/domain/IP/hash reputation	P0

	enrichment through approved threat-intelligence connectors.	
FR-06	Breach/exposure monitoring using legitimate provider APIs and user-authorized identifiers.	P0
FR-07	Risk engine combining deterministic rules with bounded AI interpretation.	P0
FR-08	Incident workflow: detect, verify, contain, recover, document.	P0
FR-09	Approval center for proposed security actions.	P0
FR-10	Tamper-evident security audit events.	P0
FR-11	Device posture agent: patch status, security configuration and selected process/network telemetry.	P1
FR-12	User-owned network inventory and anomaly detection.	P1
FR-13	Privacy audit for application/browser permissions and exposure signals where platform APIs permit.	P1
FR-14	Scheduled posture checks and notifications.	P1
FR-15	Family/team delegation with scoped roles and consent.	P2

9. Risk Scoring Model

The displayed 0-100 score is a prioritization aid, not a probability of compromise. Internally, SENTINEL should preserve component scores and evidence.

Component	Example signals
Identity	MFA posture, exposed credential indicator, suspicious session, recovery weakness
Device	Patch state, disk encryption, screen lock, risky configuration, suspicious telemetry
Network	Unknown device, insecure service exposure, anomalous destination or DNS pattern
Exposure	Known breach association, leaked identifier, public exposure
Threat	Reputation hits, phishing indicators, malicious hash/domain intelligence
Context	Asset criticality, recency, confidence, corroboration across sources

Recommended severity mapping: 0-24 Low, 25-49 Moderate, 50-74 High, 75-100 Critical. Thresholds must be configurable and validated against real alert quality.

10. AI Agent Responsibilities

Agent	Responsibility	Forbidden by default
Orchestrator	Route tasks, combine evidence, create plans.	Bypassing policy or approvals.
Threat Intelligence	Enrich indicators and summarize reputation.	Treating one provider verdict as absolute truth.
Identity & Account	Assess account posture and suspicious sessions.	Changing credentials without approval.
Device Security	Collect allowed posture/telemetry and recommend fixes.	Unrestricted admin shell.
Phishing Analysis	Analyze content, URLs, headers and social-engineering indicators.	Opening untrusted active content outside sandbox.
Network Monitor	Observe user-authorized local network and anomalies.	Scanning networks not owned/authorized by user.
Incident Response	Build containment/recovery steps and execute approved actions.	Destructive or irreversible actions without policy authorization.

11. Authorization Model

Class	Examples	Default
A - Read-only	Read local posture, parse an email supplied by user, query reputation API.	May auto-run within granted scope.
B - Reversible low impact	Quarantine a SENTINEL-managed item, disable a SENTINEL rule.	Policy-controlled; confirmation recommended.
C - Account/system change	Revoke session, modify firewall rule, stop process.	Explicit approval unless narrowly pre-authorized.
D - Destructive/irreversible	Delete data, rotate/revoke critical credentials, factory reset.	Strong confirmation; never delegated solely to LLM.

12. MVP Scope

- Web dashboard and local service.
- Asset inventory for manually added accounts/devices plus supported connectors.
- Phishing and suspicious URL analyzer.
- Breach/exposure monitoring for user-authorized identifiers.
- Threat-intelligence enrichment.
- Deterministic risk engine plus AI explanation layer.
- Personal Security Graph v1.
- Incident cards, remediation plans, approval queue and audit timeline.

Device daemon, continuous network monitoring, advanced behavioral detection and family/team mode should not block the MVP.

13. MVP User Stories

ID	User story	Acceptance criterion
US-01	As a user, I paste a suspicious message and URL.	SENTINEL returns verdict category, confidence, evidence, uncertainty and safe next steps.
US-02	As a user, I register an email for exposure monitoring.	The system stores only necessary protected identifiers and reports known supported exposure signals.
US-03	As a user, I open the dashboard.	I see current score, score drivers, critical assets and unresolved findings.
US-04	As a user, I inspect an alert.	I can trace the evidence and affected graph entities.
US-05	As a user, I approve a remediation.	The action is policy-checked, executed through a scoped adapter, verified and logged.
US-06	As a user, I reject an action.	No execution occurs and the decision is logged.

14. Non-Functional Product Requirements

- Security: encryption in transit; encrypted sensitive storage; secrets isolated from application data.
- Privacy: data minimization, configurable retention, connector-level consent and deletion controls.
- Reliability: connector failures must degrade individual features rather than break the entire product.
- Accessibility: keyboard-operable dashboard and readable severity states that do not rely only on color.
- Explainability: material findings expose source, timestamp, confidence and reasoning summary.
- Performance: local dashboard should remain responsive while enrichment and AI tasks run asynchronously.

15. Product Metrics

- Mean time from signal ingestion to prioritized finding.
- False-positive rate and user-dismissal rate by detector.
- Percentage of findings with corroborating evidence.
- Mean time to remediation and verification.
- Approval rejection rate for proposed automated actions.
- Connector health and data freshness.
- Percentage of sensitive analyses completed locally versus cloud, when local mode is enabled.

Part II - Technical Requirements Document

16. System Architecture

SENTINEL uses a modular event-driven architecture. The LLM is a reasoning and explanation component, not the security boundary. Authorization, policy evaluation, action execution and audit integrity are deterministic services.

Client UI -> API Gateway -> Auth/Session -> Orchestrator -> Policy Engine -> Domain Services/Agents
-> Event Bus -> Risk Engine + Security Graph -> Encrypted Data Layer. External intelligence and account providers connect only through scoped adapters.

17. Recommended Technology Stack

Layer	Recommendation	Reason
Web	Next.js + TypeScript	Strong dashboard ecosystem and typed frontend.
Local/API service	Python 3.12+ + FastAPI	Good fit for security tooling, async APIs and ML integrations.
Validation	Pydantic	Strict schemas at trust boundaries.
Database	PostgreSQL	Reliable relational storage; JSON support for normalized provider evidence.
Graph	PostgreSQL relational graph model initially; dedicated graph DB only if justified later	Avoid premature infrastructure complexity.
Queue	Redis Streams/Celery or equivalent durable worker system	Async enrichment, scheduled checks and retries.
Local secrets	OS keychain/secure storage; production secret manager for server deployments	Do not keep production secrets in plaintext env files.
AI	Provider-agnostic model gateway + optional local model	Privacy/cost/resilience and vendor flexibility.
Telemetry	OpenTelemetry-compatible logs/metrics/traces	Operational visibility without coupling.
Packaging	Docker for server components; signed native/local agent packages later	Reproducible deployments.

18. Major Components

Component	Responsibilities
API Gateway	Input validation, authentication boundary, rate limiting, request IDs.
Orchestrator	Task planning, agent routing, evidence aggregation, state transitions.
Policy Engine	Scope, permissions, action class, approval requirements, connector consent.

Risk Engine	Deterministic scoring, severity mapping, confidence adjustment, deduplication.
Security Graph Service	Assets, identities, indicators, findings, incidents and relationships.
Connector Service	Normalized adapters for threat intelligence, breach and account providers.
Analysis Workers	Phishing parsing, reputation checks, local static analysis and AI explanation.
Action Executor	Whitelisted typed actions with dry-run/verification support.
Audit Service	Append-oriented event records, integrity chaining and export.
Notification Service	User-configured alert delivery with severity and deduplication.
Local Agent (P1)	Device posture and explicitly authorized telemetry collection.

19. Data Model

Entity	Key fields
User	id, auth_subject, settings, privacy_mode, created_at
Asset	id, type, label, criticality, owner, status
Identity	id, asset_id, provider, protected_identifier, mfa_state
Device	id, platform, agent_id, posture_summary, last_seen
Indicator	id, type, normalized_value_hash, reputation, first_seen, last_seen
Evidence	id, source, source_ref, observed_at, confidence, normalized_payload
Finding	id, detector, severity, confidence, status, title, evidence_refs
Relationship	source_entity, relation_type, target_entity, confidence
Incident	id, status, severity, findings, timeline, owner
ActionProposal	id, action_type, target, risk_class, required_approval, status
AuditEvent	id, actor, event_type, object_ref, timestamp, previous_hash, event_hash

20. Event Model

Use versioned event envelopes so services can evolve independently.

Field	Purpose
event_id	Globally unique identifier.
event_type	Namespaced type, e.g. finding.created.
schema_version	Event compatibility.

occurred_at	Source event time.
ingested_at	SENTINEL receipt time.
source	Connector/agent/detector.
subject_refs	Related assets/identities/indicators.
classification	Data sensitivity label.
payload	Validated event-specific data.

21. API Requirements

Method / path	Purpose
POST /v1/analyze/phishing	Submit text/URL/header data for analysis.
POST /v1/indicators/enrich	Reputation enrichment for supported indicators.
GET /v1/dashboard	Aggregated posture, findings and freshness.
GET /v1/assets	Asset inventory.
GET /v1/findings	Filtered findings.
GET /v1/findings/{id}	Evidence-backed finding detail.
POST /v1/actions/{id}/approve	Approve a pending action after reauthorization where required.
POST /v1/actions/{id}/reject	Reject an action.
GET /v1/incidents/{id}	Incident state and timeline.
GET /v1/audit	Authorized audit-event query/export.

22. Security Architecture

- Zero-trust between components: authenticate service identities and authorize every sensitive operation.
- Strict input schemas and canonicalization at every connector and API boundary.
- LLM output is untrusted data. It cannot directly construct arbitrary shell commands, SQL, URLs or privileged API calls.
- Tool use is allowlisted with typed arguments. Executor maps action types to reviewed implementations.
- Separate read credentials from write/remediation credentials wherever providers allow.
- Use short-lived tokens and scoped OAuth; never log access tokens or secrets.
- Encrypt sensitive columns/records in addition to encrypted storage when threat model requires it.
- Apply SSRF controls to URL-analysis infrastructure; do not let the application server freely fetch arbitrary internal addresses.
- Analyze hostile files/content in isolated sandboxes with no sensitive credentials.
- Protect against prompt injection by separating untrusted content from system policy and requiring deterministic authorization for actions.
- Rate-limit external lookups and cache only according to provider terms and data-sensitivity policy.

23. Approval and Action Execution Protocol

8. Agent creates an ActionProposal using a fixed action schema.
9. Policy Engine evaluates actor, target, scope, action class, current risk and user policy.
10. System generates a human-readable impact preview and, where possible, a dry-run.
11. Required approval is collected; sensitive approvals may require recent reauthentication.

- 12. Executor receives only the typed approved action, never free-form LLM instructions.
- 13. Executor performs the operation with a scoped credential.
- 14. Verifier independently checks expected post-condition.
- 15. Audit Service records proposal, policy result, approval, execution result and verification.

24. Personal Security Graph

Graph edges must preserve provenance and confidence. Example relationships include USES_IDENTITY, LOGGED_IN_FROM, EXPOSED_IN, RESOLVES_TO, COMMUNICATED_WITH, AFFECTS, DERIVED_FROM and PART_OF_INCIDENT. A graph query can then escalate a finding when independent signals converge on the same high-value asset.

25. Phishing Analysis Pipeline

- 16. Normalize user input and extract URLs, domains, sender/header fields and suspicious lexical indicators.
- 17. Defang and canonicalize indicators before display or lookup.
- 18. Run deterministic checks: URL structure, domain properties, authentication/header evidence when supplied, and known reputation.
- 19. Use isolated enrichment adapters; prevent arbitrary internal-network fetching.
- 20. Optionally ask the AI layer to classify social-engineering tactics using only sanitized evidence.
- 21. Risk Engine combines signals; explanation layer reports evidence, uncertainty and safe remediation.

26. Threat-Intelligence Connector Contract

- Every connector implements lookup(), health(), rate_limit_state() and normalize().
- Provider responses are stored as normalized evidence with source attribution and timestamps.
- No provider is treated as ground truth; confidence can increase through independent corroboration.
- Provider keys are scoped, encrypted and excluded from client applications.
- Terms of service, retention and redistribution restrictions must be tracked per connector.

27. Local Device Agent - P1

- Runs as an unprivileged service by default; privilege elevation is narrowly scoped and explicit.
- Collects only configured posture signals such as OS version, patch state, disk encryption and selected security settings.
- Signs messages to the backend/local controller and uses mutual authentication.
- Supports offline buffering with bounded encrypted queues.
- Remote command surface is an allowlist of typed actions, not a generic remote shell.
- Agent updates must be signed and verified before installation.

28. Data Classification and Retention

Class	Examples	Handling
Public	Product metadata, detector version.	Normal application controls.
Internal	Non-sensitive configuration, aggregate metrics.	Authenticated access.
Sensitive	Account identifiers, findings, device posture.	Encryption, access control, retention policy.

Restricted	Tokens, cryptographic material, highly sensitive raw telemetry.	Dedicated secret storage, minimal exposure, never sent to LLM unless explicitly designed and justified.
------------	---	---

Users must be able to delete connectors and associated retained data subject to necessary security/audit retention and applicable law.

29. Authentication and Authorization

- Support strong primary authentication; prefer passkeys/WebAuthn where deployment allows.
- Use role and capability-based authorization for multi-user modes.
- Require step-up authentication for critical remediation.
- Bind action approvals to user, action hash, target and expiration to prevent approval reuse.
- Use CSRF protection and secure session-cookie settings for browser deployments.

30. Audit Integrity

Audit events should be append-oriented and integrity chained (for example, each event includes the previous event hash). This improves tamper evidence but is not a substitute for secure storage, access control, backups and external log anchoring where stronger assurance is required.

31. Observability

- Metrics: queue depth, connector latency/error rate, finding volume, action success/failure, verification failure, model latency and token/cost usage.
- Tracing: request -> orchestrator -> connector/worker -> risk -> finding/action, using correlation IDs.
- Logs: structured, redacted and sensitivity-aware; no secrets or raw credentials.
- Health: readiness/liveness plus per-connector freshness.

32. Failure Handling

Failure	Required behavior
Threat-intel provider unavailable	Mark evidence stale/unavailable; do not silently return a clean verdict.
LLM unavailable	Deterministic checks and policy engine continue; explanation may degrade.
Queue outage	Reject or locally buffer according to operation safety; never lose approved action state silently.
Action execution timeout	Move to unknown state and verify before retrying.
Verification failure	Do not report remediation as successful; escalate for review.
Compromised connector suspicion	Disable connector, revoke credential, preserve audit evidence.

33. Testing Strategy

- Unit tests for parsers, normalization, scoring and policy rules.
- Contract tests for every connector using recorded/synthetic responses.

- Property/fuzz tests for hostile URLs, headers and parser boundaries.
- Prompt-injection tests ensuring untrusted content cannot change authorization policy.
- End-to-end tests for alert -> proposal -> approval -> execution -> verification -> audit.
- Security tests: SAST, dependency scanning, secret scanning, container scanning and periodic penetration testing of SENTINEL itself.
- False-positive/false-negative evaluation datasets for phishing and risk rules, with human-reviewed labels.
- Chaos/failure tests for unavailable providers, delayed queues and partial execution.

34. Deployment Topologies

Mode	Description
Local-first	UI + API + database on user's machine; external connectors optional. Best privacy for MVP/power users.
Hybrid	Local agent/vault with cloud control plane for synchronization, notifications and heavier AI.
Managed cloud (later)	Multi-tenant control plane requiring stronger tenant isolation, compliance, key management and operational controls.

35. Repository Structure

sentinel/
 apps/
 web/
 api/
 services/
 orchestrator/
 policy/
 risk/
 graph/
 audit/
 notifications/
 workers/
 phishing/
 enrichment/
 connectors/
 threat_intel/
 breach/
 identity/
 agents/
 device/
 packages/
 schemas/
 security-sdk/

infra/
tests/
docs/

36. Delivery Roadmap

Phase	Deliverables
Phase 0 - Security foundation	Threat model, schemas, auth, vault, policy engine, audit design, CI security gates.
Phase 1 - MVP core	Dashboard, assets, phishing analyzer, indicator enrichment, breach monitoring, risk engine.
Phase 2 - Correlation	Security Graph, incidents, evidence correlation, improved prioritization.
Phase 3 - Controlled response	Approval center, typed action executor, verification adapters.
Phase 4 - Endpoint	Signed local device agent and posture collection.
Phase 5 - Advanced	Network anomaly features, privacy audits, delegated/family mode, hybrid synchronization.

37. MVP Definition of Done

- A new user can initialize SENTINEL without exposing secrets to source control or logs.
- User can analyze a suspicious message/URL and receive an evidence-backed result.
- User can register supported identifiers for exposure checks with explicit consent.
- Dashboard shows assets, unresolved findings, evidence freshness and score drivers.
- Findings are deduplicated and linked to graph entities.
- No LLM output can bypass the Policy Engine or invoke arbitrary commands.
- All security actions are typed, scoped, approval-checked, verified and audited.
- Automated security tests run in CI and critical findings block release.
- Backup/restore and data deletion paths are tested.
- Documentation includes privacy model, threat model, connector permissions and recovery procedures.

38. Key Engineering Decisions

- Do not start with microservices everywhere. A modular monolith plus workers is enough for MVP and easier to secure.
- Do not introduce a dedicated graph database until graph workload proves PostgreSQL inadequate.
- Do not let AI calculate the authoritative risk score. AI may explain or propose; deterministic code owns policy and scoring.
- Do not build a generic remote shell into the endpoint agent.
- Do not claim 'continuous protection' until telemetry coverage and background execution are actually reliable on supported platforms.

39. Open Decisions Before Implementation

- Initial deployment target: desktop-local, self-hosted server, or managed hybrid.
- Supported operating systems for the first device agent.
- Which identity/email providers are in MVP and what permissions each requires.

- Local model requirements and minimum hardware.
- Data residency and compliance requirements if a cloud service is offered.
- Notification channels and escalation rules.
- Exact provider selection for breach and threat-intelligence data, based on API terms and budget.

40. Final Architecture Rule

SENTINEL must treat the AI model as an untrusted advisor inside a trusted security system.

The security boundary is formed by validated schemas, explicit scopes, deterministic policy, typed executors, strong authentication, isolation, verification and audit. That distinction is what separates a credible security product from an LLM with dangerous permissions.